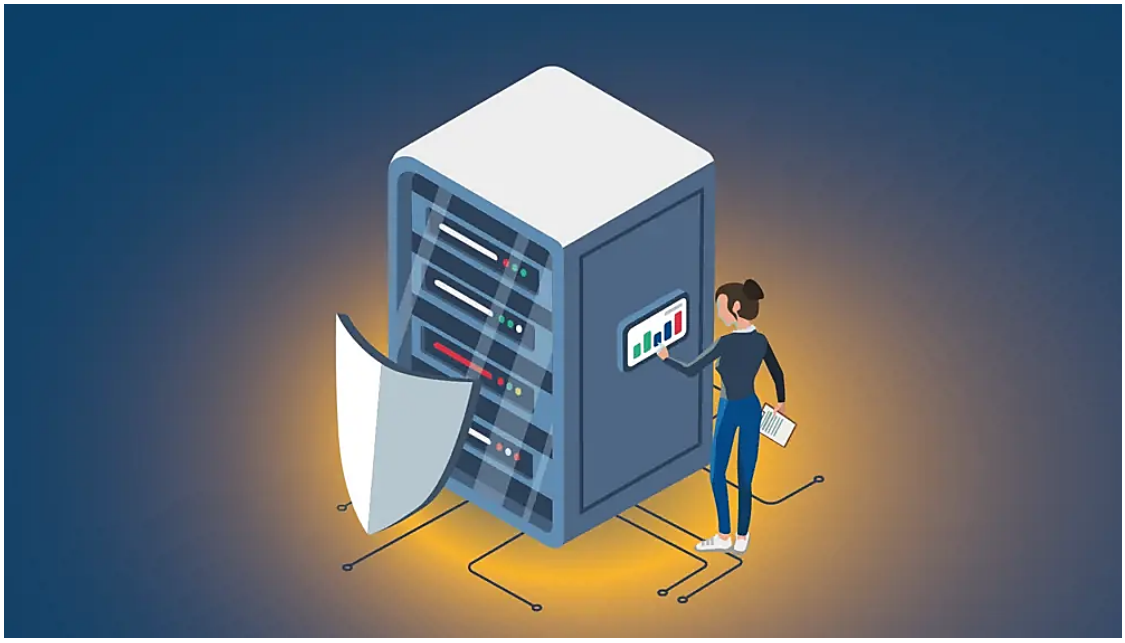
IUT de Paris - Rives de Seine
Université Paris Cité

DOSSIER

SAE Conformité réglementaire pour traiter des données

Eda BASARAN



Dossier – Conformité RGPD et AIPD

Jeu de données : achats_clients_campagnes jointure de clients.csv, achats.csv et campagnes.csv
Contexte : grande distribution – marketing et fidélisation client

Contexte général du traitement

L'entreprise de grande distribution SuperPlus exploite un fichier **achats_clients_campagnes** regroupant des informations liées aux achats, à l'identité des clients et à leur exposition à des campagnes marketing. Ces données sont utilisées à des fins de gestion commerciale, d'analyse comportementale et de communication promotionnelle via différents canaux (email, SMS).

Le traitement repose sur une base de données contenant 1 000 lignes et 18 variables, combinant données transactionnelles, données d'identification et données marketing.

Ce contexte implique un **traitement de données personnelles à des fins de profilage**, ce qui justifie la réalisation d'une **Analyse d'Impact relative à la Protection des Données (AIPD)** conformément à l'article 35 du RGPD.

Veille RGPD – Grande distribution

Dans le secteur de la grande distribution, la CNIL et les autorités européennes ont identifié plusieurs points de vigilance récurrents. Les enseignes traitent des volumes importants de données clients, souvent croisées entre achats, fidélité et campagnes marketing. Les recommandations portent notamment sur :

- la **transparence des traitements** de fidélisation et de marketing ;
- l'**encadrement du profilage** basé sur les habitudes d'achat, afin d'éviter toute discrimination ou ciblage abusif ;
- le **respect du consentement** pour les communications commerciales, y compris la possibilité de retrait à tout moment ;
- le **respect du principe de minimisation des données**, en limitant la collecte aux seules informations strictement nécessaires à la finalité poursuivie (ex. éviter les données excessives dans les programmes de fidélité ou les campagnes marketing) ;
- la **limitation de la durée de conservation** des données marketing et clients, avec suppression ou anonymisation après usage ;
- la **sécurisation renforcée** des coordonnées de contact (email, téléphone) et des données sensibles ;
- la **traçabilité des accès et traitements**, notamment pour les partenaires et prestataires externes ;
- la **mise en œuvre de procédures ARCP** (Accès, Rectification, Suppression, Opposition) pour garantir les droits des clients.

Les décisions de sanction concernent fréquemment :

- des durées de conservation excessives ;
- un consentement insuffisamment explicite pour les campagnes marketing ;
- une information incomplète des personnes concernées ;
- l'absence de mesures de sécurité adaptées, en particulier pour les données sensibles ;
- un suivi insuffisant des traitements confiés à des prestataires externes.

Ces éléments constituent le cadre de référence pour l'analyse du jeu de données étudié, permettant d'évaluer les risques, de définir les mesures de sécurité et de garantir la conformité au RGPD dans les traitements marketing et analytiques.

Identification des données personnelles

Le fichier contient plusieurs catégories de données personnelles :

Données d'identification directe

Les variables suivantes permettent d'identifier directement une personne :

- nom
- prénom
- email
- téléphone

Données d'identification indirecte

Les variables suivantes permettent d'identifier indirectement une personne en reliant plusieurs données :

- client_id
- ville
- âge
- sexe
- détention d'une carte de fidélité

Données comportementales et de profilage

Le fichier contient également des données révélant les habitudes de consommation :

- date d'achat
- catégorie de produits
- montant des achats
- participation à une campagne marketing
- canal de communication utilisé

L'ensemble de ces données constitue un **profil client**, utilisé à des fins d'analyse et de ciblage commercial.

Tableau synthétique de l'AIPD

1. Description du traitement

1ère finalité	*2ème finalité*
Mieux comprendre le comportement de ses clients	Suivre l'efficacité des campagnes marketing
Base légale : Intérêt légitime Balance d'intérêt : - Superplus : développement d'une relation commerciale - Clients : permet aux clients de bénéficier d'offres plus pertinentes et d'une expérience d'achat améliorée.	Base légale : Intérêt légitime Balance d'intérêt : - Superplus : amélioration des ventes - Clients : permet de limiter les sollicitations inutiles et de recevoir des communications plus pertinentes.

Type de données	*Durée de conservation (Conforme à la CNIL)*
Identité & contacts (nom, prenom, email, telephone, ville)	3 ans après le dernier contact commercial ou la fin de la relation commerciale
Historique d'achats (achat_id, date_achat, categorie, montant)	3 à 5 ans maximum à des fins d'analyse commerciale, puis anonymisation pour les analyses statistiques.
Données fidélité (carte_fidelite)	3 ans après la dernière utilisation
Données campagnes (campagne_associee, nom_campagne, canal, budget, objectif)	2 à 3 ans après la fin de la campagne
Données démographiques (age, sexe)	3 ans ou jusqu'à anonymisation

Lieu de stockage	*Mesures de sécurité*
Serveurs internes de SuperPlus situés en France / Union européenne	Accès restreint aux personnes autorisées, chiffrement des données, sauvegardes régulières.

2. Analyse des risques et mesures de sécurité envisagées

Risque	*Description du risque*	*Mesures de sécurité*
R1 : Fuite de données personnelles	Divulgation accidentelle ou malveillante des données clients (email, téléphone, historique d'achats). **Causes** : emails non sécurisés, attaque informatique, faille de sécurité.	Chiffrement des données, sécurisation des échanges (HTTPS), sauvegardes sécurisées, procédure de gestion des violations de données.
R2 : Accès non autorisé	Consultation ou utilisation des données par des personnes non habilitées. **Causes** : droits d'accès trop larges, comptes d'anciens collaborateurs actifs.	Gestion stricte des habilitations, authentification forte, suppression régulière des comptes inactifs, journalisation des accès.
R3 : Conservation excessive des données	Conservation des données personnelles au-delà de la durée nécessaire. **Causes** : absence de politique de purge ou d'anonymisation.	Politique de conservation formalisée, automatisation de la suppression ou anonymisation des données arrivées à échéance.
R4 : Utilisation inappropriée des données	Détournement de la finalité initiale, profilage excessif ou discriminatoire des clients. **Causes** : dérive des usages marketing.	Définition claire de la finalité, contrôles internes, limitation des analyses, sensibilisation des équipes au RGPD.
R5 : Données inexactes	Analyses ou décisions basées sur des données erronées ou obsolètes. **Causes** : erreurs de saisie, synchronisation défaillante entre systèmes.	Procédures de contrôle qualité, mises à jour régulières, possibilité pour les clients de corriger leurs données.
R6 : Non-respect des droits des personnes (ARCP)	Difficulté pour les clients d'exercer leurs droits d'accès, de rectification, d'effacement ou d'opposition. **Causes** : processus manuel, manque de formation des équipes.	Procédure dédiée aux droits RGPD, formation des équipes, délais de traitement encadrés et suivis.

3. Estimation du niveau de risque

Vraisemblance : Probabilité que le risque se produise
Gravité : Importance des conséquences si le risque se produit
Niveau de risque estimé : Résultat du croisement vraisemblance × gravité

Risque	*Vraisemblance*	*Gravité*	*Niveau de risque estimé*
R1 : Fuite de données personnelles	Moyenne	**Critique**	**Élevé**
R2 : Accès non autorisé	Moyenne	**Critique**	**Élevé**
R3 : Conservation excessive des données	**Élevée**	Modérée	**Élevé**
R4 : Utilisation inappropriée des données	Faible	**Critique**	**Modéré à Élevé**
R5 : Données inexactes	Moyenne	Modérée	Modéré
R6 : Non-respect des droits ARCP	Moyenne	Modérée	Modéré

4. Validation du traitement ou non ?

Critère évalué	*État*	*Justification*
Finalités définies et légitimes	**Validé**	**Finalités clairement définies : analyse du comportement client et de l'efficacité des campagnes marketing.**
Base légale appropriée	**Validée**	**Traitement fondé sur l'intérêt légitime de l'entreprise.**
Durée de conservation définie	**À améliorer**	**Durées définies mais nécessité de mise en œuvre d'une purge ou anonymisation automatique.**
Sécurité des données	**À améliorer**	**Mesures prévues (chiffrement, contrôle d'accès) mais doivent être formalisées et appliquées.**
Droits des personnes (ARCP)	**À améliorer**	**Procédures identifiées mais à formaliser et documenter.**
Niveau de risque résiduel	**Acceptable**	**Les risques résiduels sont jugés acceptables après mise en place des mesures.**
Validation globale du traitement	**VALIDÉ SOUS CONDITIONS**	**Traitement autorisé sous réserve de la mise en œuvre effective des mesures correctives identifiées.**

5. Procédure cas de modification de traitement

Étape	*Action à réaliser*	*Responsable*	*Résultat attendu*
1	**Identification de la modification du traitement**	**Responsable du traitement**	**Modification formalisée et décrite**
2	**Analyse de l'impact de la modification (finalité, données, accès, sécurité)**	**Équipe data / DPO**	**Évaluation de la portée du changement**
3	**Mise à jour de l'AIPD**	**DPO / Responsable du traitement**	**AIPD actualisée avec nouveaux risques**
4	**Réévaluation des risques**	**DPO / Équipe data**	**Niveau de risque mis à jour**
5	**Validation interne**	**Direction / DPO**	**Décision de validation ou non**
6	**Information des personnes concernées**	**Service communication**	**Politique de confidentialité mise à jour**
7	**Mise en œuvre des mesures de sécurité**	**Équipe IT**	**Mesures appliquées et opérationnelles**
8	**Traçabilité et suivi**	**Responsable du traitement**	**Historique des modifications conservé**

Appréciation finale du niveau de risque et solutions proposées

Après analyse détaillée des données personnelles collectées et traitées dans le cadre du traitement achats_clients_campagnes, ainsi que de l'ensemble des risques identifiés (R1 à R6), l'appréciation finale du niveau de risque peut être formulée comme suit :

1. Niveau de risque global

- Les risques les plus critiques concernent la fuite de données personnelles (R1), l'accès non autorisé (R2) et la conservation excessive des données (R3).
- Les risques modérés incluent l'utilisation inappropriée des données (R4), les données inexactes (R5) et le non-respect des droits ARCP (R6).
- Conclusion : le traitement présente un niveau de risque initial élevé, principalement en raison des données personnelles identifiantes (nom, prénom, email, téléphone, historique d'achats) et de la sensibilité des informations liées aux campagnes marketing.

2. Solutions et mesures proposées

Pour réduire les risques à un **niveau résiduel acceptable**, les mesures suivantes ont été définies :

1. **Sécurité technique**
    - Chiffrement des données en stockage et en transit.
    - Sauvegardes régulières et sécurisées.
    - Authentification forte et gestion stricte des droits d'accès.
    - Journalisation des accès et traçabilité des actions.
2. **Organisation et gouvernance**
    - Mise en place d'une politique de conservation des données avec suppression ou anonymisation automatique au terme des durées définies.
    - Définition claire de la finalité du traitement et limitation des usages marketing.
    - Sensibilisation et formation des équipes aux obligations RGPD et aux bonnes pratiques.
3. **Respect des droits des personnes**
    - Procédure formalisée pour l'exercice des droits ARCP (Accès, Rectification, Suppression, Opposition).
    - Possibilité pour les clients de corriger ou mettre à jour leurs informations.

3. Conclusion

Le traitement des données personnelles peut être validé, sous réserve de la mise en œuvre effective de l'ensemble des mesures proposées.

Ces solutions permettent de réduire les risques identifiés à un niveau résiduel acceptable, garantissant la protection des données personnelles et la conformité au RGPD, tout en permettant à SuperPlus d'analyser efficacement le comportement de ses clients et l'efficacité de ses campagnes marketing.

Annexe

Annexe – Description détaillée du jeu de données

Nom de la variable	Type de donnée	Description	Caractère personnel
achat_id	Numérique	Identifiant unique de l'achat	Non
client_id	Numérique	Identifiant pseudonymisé du client	Oui (indirect)
date_achat	Date	Date de réalisation de l'achat	Oui (indirect)
categorie	Texte	Catégorie du produit acheté	Non
montant	Numérique	Montant de l'achat	Oui (indirect)
campagne_associee	Numérique	Identifiant de la campagne associée à l'achat	Non
nom	Texte	Nom du client	Oui
prenom	Texte	Prénom du client	Oui
age	Numérique	Âge du client	Oui
sexe	Texte	Sexe du client	Oui
email	Texte	Adresse email du client	Oui
telephone	Texte	Numéro de téléphone du client	Oui
ville	Texte	Ville de résidence du client	Oui
carte_fidelite	Booléen	Indique si le client possède une carte de fidélité	Oui
nom_campagne	Texte	Nom de la campagne marketing	Non
canal	Texte	Canal de diffusion de la campagne (Email, SMS…)	Non
budget	Numérique	Budget alloué à la campagne	Non
objectif	Texte	Objectif de la campagne marketing	Non